

Threat Analysis Report

รายงานวิเคราะห์ภัยคุกคาม VECT
Ransomware 2.0 – ความล้มเหลวเชิง
โครงสร้างสู่ภัยคุกคามประเภททำลายข้อมูล
(Wiper)

12/05/2026

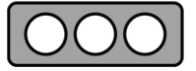
TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
Threat Actor Profile	4
การวิเคราะห์เชิงเทคนิค.....	6
Technique Tactics and Procedures (MITRE ATT&CK).....	10
Indicator of Compromise (IOCs).....	11
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....	12
อ้างอิง (References).....	14



บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์เชิงลึกถึงพฤติกรรมของ VECT Ransomware เวอร์ชัน 2.0 ที่พยายามสร้างภาพลักษณ์เป็นผู้ให้บริการ RaaS ระดับมืออาชีพ แต่แท้จริงแล้วมีข้อบกพร่องขั้นรุนแรงในการออกแบบจนกลายเป็นมัลแวร์ทำลายข้อมูลโดยไม่ได้ตั้งใจ

ความผิดพลาดหลักเกิดจากการใช้โครงสร้างเข้ารหัส Raw ChaCha20-IETF โดยไม่มีกลไกตรวจสอบความถูกต้องประกอบกับมีบักร้ายแรงในการจัดการค่า Nonce เมื่อมัลแวร์ทำการเข้ารหัสไฟล์ที่มีขนาดใหญ่กว่า 128 KB (131,072 ไบต์) มันจะแบ่งไฟล์ออกเป็น 4 ส่วน แต่ความสับสนในการเขียนโค้ดทำให้ค่า Nonce ถูกเขียนทับตำแหน่งเดิมซ้ำ ๆ ส่งผลให้ ค่า Nonce ของ 3 ส่วนแรกสูญหายไปตลอดกาล ข้อมูลที่มีความสำคัญระดับองค์กร เช่น ฐานข้อมูล หรือไฟล์ดิสก์ของเครื่องเสมือน (VMDK) จึงถูกทำลายทิ้งตั้งแต่ขั้นตอนเข้ารหัส ซึ่งปัญหานี้ฝังอยู่ในโค้ดหลักและส่งผลกระทบต่อทุกแพลตฟอร์มทั้ง Windows Linux และ ESXi

ในด้านการดำเนินงาน กลุ่ม VECT ได้สร้างเครือข่ายความร่วมมือกับกลุ่ม TeamPCP เพื่อใช้ช่องทางจากการโจมตีห่วงโซ่อุปทานในซอฟต์แวร์ยอดนิยม (เช่น Trivy LiteLLM Telnyx) และใช้โมเดลธุรกิจแบบ Open Affiliate แจกจ่าย Access Key ผ่านเว็บบอร์ด BreachForums ให้สมาชิกทุกคนสามารถนำไปใช้งานได้อย่างเปิดกว้าง อย่างไรก็ตาม การขยายเครือข่ายอย่างเร่งรีบนี้กลับเต็มไปด้วยข้อผิดพลาดระดับมือสมัครเล่น เช่น โหมดความเร็วในการเข้ารหัสที่กำหนดไว้แต่ใช้งานไม่ได้จริง และระบบหลบหลีกการวิเคราะห์ที่เขียนโค้ดทิ้งไว้แต่ไม่เคยถูกเรียกใช้งาน

จากข้อเท็จจริงทั้งหมดนำไปสู่ข้อสรุปที่เด็ดขาดว่า การจ่ายค่าไถ่ไม่ใช่วิธีการแก้ปัญหา เพราะแม้แต่ผู้โจมตีเองก็ไม่สามารถกู้คืนข้อมูลที่ถูกลบของตนทำลายไปได้ องค์กรจึงควรประเมินสถานการณ์นี้เทียบเท่ากับการถูกโจมตีทำลายล้างข้อมูล โดยมีความจำเป็นอย่างยิ่งที่จะต้องพึ่งพากระบวนการสำรองข้อมูลแบบออฟไลน์ในการกู้ระบบ และเผื่อระวังจุดอ่อนจากห่วงโซ่อุปทานอย่างเข้มงวด



Threat Actor Profile

โปรไฟล์ภัยคุกคามของกลุ่ม VECT

1. ประวัติและภูมิหลัง

กลุ่ม VECT ปรากฏตัวครั้งแรกในเดือนธันวาคม ปี 2025 บนฟอรัมอาชญากรรมไซเบอร์ที่ใช้ภาษารัสเซียโดยดำเนินงานในรูปแบบ Ransomware-as-a-Service (RaaS) ที่ใช้โมเดลการขู่กรรโชกซ้ำซ้อน (Double-extortion) ซึ่งก็คือการขโมยข้อมูลออกมาก่อนที่จะทำการเข้ารหัสเพื่อข่มขู่เหยื่อให้จ่ายค่าไถ่

ในเดือนมกราคม 2026 กลุ่มนี้ได้ประกาศเปิดตัวโปรแกรมพันธมิตร (Affiliate Program) อย่างเป็นทางการบนเว็บไซต์ และต่อมาในเดือนกุมภาพันธ์ 2026 ได้เปิดตัวมัลแวร์เวอร์ชันอัปเดตในชื่อ Vect 2.0

ในช่วงเดือนมีนาคมและเมษายน 2026 VECT ได้ประกาศความร่วมมือเชิงกลยุทธ์กับ TeamPCP (กลุ่มแฮกเกอร์ที่อยู่เบื้องหลังการโจมตีซีพียูหลายเซกในซอฟต์แวร์อย่าง Trivy โดยอาศัยช่องโหว่รหัส CVE-2026-33634 ซึ่งส่งผลกระทบต่อเนื่องไปยังซอฟต์แวร์ LiteLLM Checkmarx KICS และ Telnyx) เพื่อนำการเข้าถึงที่ TeamPCP มีมาใช้ในการปล่อยแรนซัมแวร์ นอกจากนี้ยังได้ร่วมมือกับ BreachForums โดยทำการแจกจ่ายคีย์เพื่อเป็นพันธมิตร (Affiliate Keys) ให้กับสมาชิกของเว็บไซต์ทุกคนโดยอัตโนมัติ เพื่อขยายฐานผู้โจมตีอย่างรวดเร็ว

แม้จะมีการเก็บค่าธรรมเนียมแรกเข้า 250 ดอลลาร์สหรัฐ (ชำระผ่านเหรียญ Monero หรือ XMR) แต่ VECT ยกเว้นค่าธรรมเนียมให้กับผู้ที่มาจากประเทศในกลุ่มเครือรัฐเอกราช (CIS) หรือประเทศที่ใช้ภาษารัสเซีย ซึ่งเป็นพฤติกรรมที่ชี้ให้เห็นว่าผู้ดูแลระบบของกลุ่มนี้น่าจะมีฐานปฏิบัติการอยู่ในภูมิภาคดังกล่าว (เช่น รัสเซีย หรือ เบลารุส) นอกจากนี้ยังใช้โปรโตคอล TOX ในการสื่อสารเพื่อความปลอดภัย

VECT มีการใส่สตริงอ้างอิงถึงมัลแวร์ชื่อ DEVMAN 3.0 ในโค้ดเพื่อสร้างความสับสนและพยายามทำให้ดูเหมือนเป็นมัลแวร์ที่มีความเชื่อมโยงกับกลุ่มอื่นที่น่าเชื่อถือ แต่ในความเป็นจริง การเขียนโปรแกรมของ VECT มีข้อบกพร่องร้ายแรง ที่ทำให้ไฟล์ที่มีขนาดใหญ่กว่า 128 KB ถูกทำลายอย่างถาวร และไม่สามารถกู้คืนได้แม้จะจ่ายค่าไถ่ก็ตาม

2. เครื่องมือการโจมตี

VECT 2.0 Ransomware (Custom C++ Encryptor): เป็นมัลแวร์ที่เขียนขึ้นใหม่ด้วยภาษา C++ สามารถสร้างเพย์โหลดเพื่อโจมตีได้ถึง 3 แพลตฟอร์มหลัก คือ Windows (PE64), Linux (ELF64) และ VMware ESXi (ELF64)



3. กลุ่มเป้าหมาย

- **เป้าหมายทางอุตสาหกรรม:** VECT 2.0 พุ่งเป้าไปที่ ภาคการผลิต ภาคการศึกษา ภาคสาธารณสุข เทคโนโลยี และผู้ให้บริการด้านวิศวกรรม
- **เป้าหมายทางภูมิศาสตร์:** เป็นกลุ่มที่มีการโจมตีแบบสุ่มระดับโลก ไม่ได้จำกัดเป้าหมายในพื้นที่ใดพื้นที่หนึ่งโดยเฉพาะ จากสถิติเหยื่อบน Leak Site ในช่วงเดือนมกราคม - กุมภาพันธ์ 2026 พบว่ามีเหยื่อกระจายอยู่ในหลายประเทศ เช่น บราซิล สหรัฐอเมริกา อินเดีย แอฟริกาใต้ อียิปต์ สเปน โคลอมเบีย อิตาลี นามิเบีย และเกาหลีใต้
- **การตั้งค่าละเว้นเป้าหมาย:** มัลแวร์เวอร์ชัน Linux และ ESXi มีกลไกการตรวจสอบพิกัดเวลาและรหัสประเทศ หากตรวจพบว่าระบบตั้งอยู่ในกลุ่มประเทศเครือรัฐเอกราช (CIS) รวมถึงรัสเซีย หรือยูเครน มัลแวร์จะทำการยุติการทำงานและไม่เข้าสู่กระบวนการเข้ารหัส



การวิเคราะห์เชิงเทคนิค

จากการวิเคราะห์เชิงลึกของมัลแวร์ VECT 2.0 (Ransomware-as-a-Service) สามารถสรุปลำดับขั้นตอนการโจมตี (Attack Flow) และเจาะลึกโครงสร้างทางเทคนิคและวิศวกรรมรหัสลับที่ล้มเหลว ซึ่งส่งผลให้มัลแวร์ตัวนี้มีพฤติกรรมเป็นมัลแวร์ทำลายข้อมูล (Wiper) โดยไม่ได้ตั้งใจ ดังนี้

ลำดับขั้นตอนการโจมตี (Attack Flow)

1. : การเจาะระบบเบื้องต้นผ่าน Supply Chain

กลุ่มผู้โจมตีอาศัยช่องทางการเข้าถึงจากกลุ่ม TeamPCP ที่ทำการโจมตีห่วงโซ่อุปทานผ่านช่องโหว่รหัส CVE-2026-33634 ในส่วนขยาย GitHub Actions ของ Trivy ทำให้สามารถขโมย Secrets ใน CI/CD Pipeline และนำไปใช้ฝังมัลแวร์ในซอฟต์แวร์อื่นต่อ ก่อนจะส่งมอบช่องทางนี้ให้ VECT นำมาเรียกค่าไถ่

2. : การเริ่มทำงานและหลบหลีกการตรวจจับ

ระบบ ESXi/Linux: มัลแวร์เริ่มต้นด้วยการตรวจสอบ Geofencing เพื่อหลีกเลี่ยงการทำงานในกลุ่มประเทศ CIS (รัสเซีย ยูเครน เบลารุส คาซัคสถาน คีร์กีซสถาน ทาจิกิสถาน เติร์กเมนิสถาน อุซเบกิสถาน อาร์เมเนีย อาเซอร์ไบจาน จอร์เจีย มอลโดวา และ เซอร์เบีย) โดยมีการตรวจสอบการตั้งค่าภาษาและ Timezone หากตรงกับเงื่อนไข มัลแวร์จะหยุดทำงานทันที

ระบบ Windows: มัลแวร์ใช้คำสั่ง PowerShell (Set-MpPreference -DisableRealtimeMonitoring \$true...) เพื่อปิดการทำงานของ Windows Defender รวมถึง Real-time protection, Behavior monitoring และ Script scanning โดยซ่อนคำสั่งไว้ด้วยการเข้ารหัสแบบ XOR

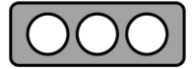
Anti-analysis (Dead Code): ในเวอร์ชัน Windows มีการเตรียมโค้ดเพื่อตรวจจับเครื่องมือวิเคราะห์ถึง 44 รายการ (เช่น ollydbg.exe wireshark.exe) แต่ฟังก์ชันนี้ไม่ได้ถูกเรียกใช้จริง

3. : การเตรียมระบบและการระงับบริการ

ESXi: มีการใช้คำสั่ง esxcli เพื่อตัดแปลงและปิดการทำงานของ Firewall และกฎต่าง ๆ ตลอดจนรันคำสั่งหยุดการทำงานของ Virtual Machine (VM) ผ่านเครื่องมือต่าง ๆ เช่น VBoxManage virsh และ vmware-cmd

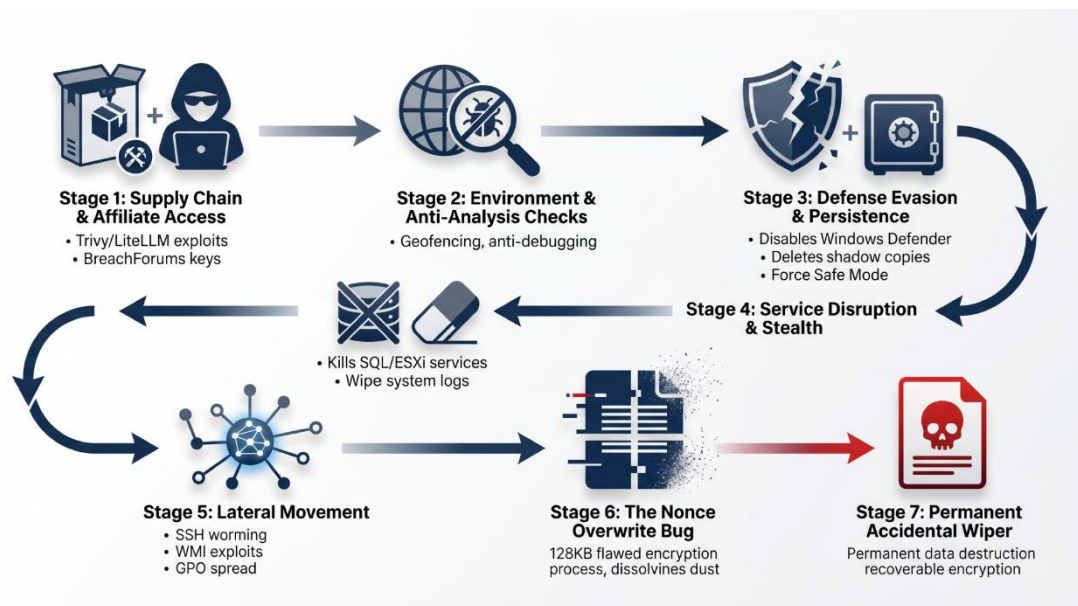
4. : การฝังตัวและการเคลื่อนที่แนวราบ

สำหรับระบบปฏิบัติการ Windows มัลแวร์จะทำการฝังตัวโดยใช้คำสั่ง bcdedit เพื่อบังคับให้ระบบบูตเข้าสู่โหมดปลอดภัยในวงถัดไป ควบคู่กับการเพิ่มค่า Registry เพื่อให้มัลแวร์ทำงานโดยอัตโนมัติ ในขณะที่แพลตฟอร์ม ESXi และ Linux จะใช้กลไกการเคลื่อนที่แนวราบผ่านโปรโตคอล SSH โดยทำการขโมย Private keys และดึงรายชื่อโฮสต์เป้าหมายจากไฟล์ known_hosts เพื่อแพร่กระจายตัวเองไปยังเครื่องอื่นในเครือข่าย



5. : การเข้ารหัสและการทำลายข้อมูลถาวร

มัลแวร์จะเปลี่ยนชื่อไฟล์โดยต่อท้ายด้วยนามสกุล .vect ก่อนที่จะเข้าสู่การเข้ารหัสแบบ ChaCha20-IETF ซึ่งจะส่งผลให้ข้อมูลถูกทำลายอย่างถาวรในไฟล์ขนาดใหญ่



รูปที่ 1 : แผนภาพการโจมตี

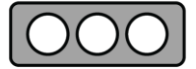
การวิเคราะห์เชิงเทคนิคและวิศวกรรมรหัสลับ

ความล้มเหลวเชิงโครงสร้างของ VECT 2.0 อยู่ที่ยังการบริหารจัดการ Nonce ซึ่งเป็นกุญแจหลักของ Stream Cipher

การแก้ไขความเข้าใจผิดเชิงรหัสลับ VECT 2.0 ไม่ได้ใช้ ChaCha20-Poly1305 AEAD ตามที่ผู้พัฒนาโฆษณาไว้ แต่แท้จริงแล้วมันใช้เพียง Raw ChaCha20-IETF (RFC 8439) ผ่านไลบรารี libsodium โดยไม่มี Poly1305 Authentication Tag ทำให้ไม่มีการปกป้องความถูกต้องของข้อมูล

กลไกการทำลายข้อมูล สำหรับไฟล์ที่มีขนาดเกิน 131,072 ไบต์ (128 KB) มัลแวร์จะแบ่งไฟล์เป็น 4 Chunks ซึ่งมีข้อผิดพลาดอย่างร้ายแรง ดังนี้:

1. ในแต่ละ Chunk มัลแวร์จะเรียก randombytes() ของ libsodium เพื่อสร้างค่า Nonce 12-byte ชุดใหม่
2. **Shared Buffer Overwrite:** ค่า Nonce กลับถูกนำไปเขียนทับลงในหน่วยความจำเดียวกัน ส่งผลให้ Nonce ของ Chunk ที่ 1 2 และ 3 ถูกลบออกจากหน่วยความจำทันที
3. **Data Destruction:** มัลแวร์บันทึกเพียง Nonce ตัวสุดท้ายที่เหลือรอดลงท้ายไฟล์ ทำให้ Nonce 3 ตัวแรกสูญหายไปตลอดกาล



ขนาดไฟล์	ส่วนประกอบที่กู้คืนได้	สถานะความเสียหาย
≤ 131,072 ไบต์ (128 KB)	กู้คืนได้ทั้งหมด	ปลอดภัย (หากได้รับกุญแจถอดรหัส)
> 131,072 ไบต์ (128 KB)	เฉพาะข้อมูล Chunk ที่ 4 (ตำแหน่ง 75%)	75% ของข้อมูลที่ถูกเข้ารหัสจะสูญหายถาวร

สภาวะนี้คือ Cryptographic Erasure เนื่องจากตัวเลขสุ่มถูกสร้างขึ้นใหม่และเขียนทับโดยไม่ได้จัดเก็บสำรองที่ใดเลย ทำให้การกู้คืนไฟล์ขนาดใหญ่เป็นไปได้ไม่ได้ในทางคณิตศาสตร์

การวิเคราะห์พฤติกรรมข้ามแพลตฟอร์ม

VECT 2.0 ใช้ Single Codebase ทำให้บีกที่ทำลายข้อมูลตัวนี้กระจายไปยังระบบปฏิบัติการที่รองรับทั้งหมด

```

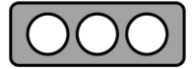
disable_esxi_firewall_and_security();
stop_esxi_services();
kill_esxi_processes();
kill_backup_software_processes();
if ( flag_kill_vms )
    mw_kill_vms_via_vim_cmd();
kill_security_and_db_processes();
stop_security_and_db_services();
kill_vm_process_list();
wipe_shell_history();
wipe_system_logs();
wipe_esxi_logs();
build_encryption_target_list(&enc_ctx, &a_vmfs_volumes);
encrypt_all_datastores(&enc_ctx, &a_vmfs_volumes);
}
p_a_vmfs_volumes = &a_vmfs_volumes;
drop_ransom_note_to_dirs(&enc_ctx, &a_vmfs_volumes);
if ( config.set_motd )
    drop_ransom_note_motd(&enc_ctx);
if ( spread_flag_set )
{
    ssh_steal_private_keys(v76);
    ssh_wipe_known_hosts(&v104);
    ssh_parse_config_files(&v106);

    kill_security_and_db_processes();
    stop_security_and_db_services();
    kill_vm_process_list();
    wipe_shell_history();
    wipe_system_logs();
    encrypt_files(enc_ctx, target_path);
    v12 = target_path;
    drop_ransom_note_to_dirs(enc_ctx, target_path);
    if ( cfg_flag_set_motd )
        drop_ransom_note_motd(enc_ctx);
    if ( spread_flag_set )
    {
        ssh_steal_private_keys(v76);
        ssh_wipe_known_hosts(v77);
        ssh_parse_config_files(v78);
    }
}

```

รูปที่ 2 : Execution flow ESXi locker (left) vs. Linux locker (right) แสดงความเหมือนของ Codebase

ภาพเปรียบเทียบขั้นตอนการทำงานหลักระหว่างมัลแวร์เวอร์ชัน ESXi (ซ้าย) และ Linux (ขวา) ซึ่งแสดงให้เห็นถึงลำดับการเรียกใช้ฟังก์ชันที่เหมือนกัน เช่น การสั่งหยุดบริการระบบโพเรส ล้างข้อมูลประวัติล็อกไฟล์ และขั้นตอนการเริ่มเข้ารหัส เป็นหลักฐานยืนยันชัดเจนว่ามัลแวร์ทั้งสองเวอร์ชันถูกพัฒนาขึ้นมาจากการใช้ Codebase เดียวกัน



```
// Big files: Chunk in 4 32KB chunks
bytes_total = 0;
n_chunks = 4;
do
{
    if ( !fseek(h_file, bytes_total, 0) )
    {
        chunk_size = file_size - bytes_total;
        if ( file_size >= bytes_total + 0x8000 )
            chunk_size = 0x8000;
        chunk_size_read = chunk_size;
        if ( chunk_size == IO_fread(chunk_buf, 1, chunk_size, h_file) )
        {
            if ( chunk_size_read )
            {
                chunk_scan_ptr = chunk_buf;
                while ( !*chunk_scan_ptr )
                {
                    chunk_scan_ptr = (chunk_scan_ptr + 1);
                    if ( (chunk_buf + chunk_size_read) == chunk_scan_ptr )
                        goto next_chunk;
                }
                chacha20_encrypt_file_buffer(a3, chunk_buf, chunk_size_read, nonce);
                fseek(h_file, bytes_total, 0);
                IO_fwrite(chunk_buf, 1, chunk_size_read, h_file);
            }
        }
    }
}
next_chunk:
bytes_total += file_size >> 2;
--n_chunks;
}
while ( n_chunks );
// Append ONLY THE LATEST ChaCha20 nonce (12 byte) & close file
fseek(h_file, 0, 2);
IO_fwrite(nonce, 1, 12, h_file);
```

รูปที่ 3 : Encryption flaw (ESXi version) แสดงบั๊กแบบเดียวกันในฝั่ง ESXi

ภาพส่วนหนึ่งของซอร์สโค้ดในเวอร์ชัน ESXi ซึ่งแสดงให้เห็นถึงบั๊กการเข้ารหัสที่ผิดพลาดในไฟล์ขนาดใหญ่ (เกิน 128 KB) จะเห็นได้ว่าคำสั่ง `IO_fwrite(nonce, 1, 12, h_file)` ที่ใช้สำหรับบันทึกค่า Nonce ถูกวางไว้ที่ด้านนอกหลังจบการทำงานของลูป ทำให้มีลแวงบันทึกเพียงค่า Nonce ตัวสุดท้ายลงท้ายไฟล์ ส่งผลให้ค่า Nonce ในลูปก่อนหน้านี้ถูกเขียนทับและสูญหายไปอย่างถาวร นอกจากนี้ ยังมีพฤติกรรมเชิงลบและการออกแบบที่ผิดพลาดแยกตามแพลตฟอร์ม ดังนี้

Windows Variant:

- **Threading Overkill:** ผู้พัฒนาตั้งค่าให้ประมวลผล Thread สูงเกินไป (เช่น 48 Threads บน CPU แบบ 8 core) ทำให้เกิดการแย่งชิง IO Channel (IO Channel Saturation) ส่งผลให้ประสิทธิภาพการทำงานของระบบตกลงอย่างหนัก แทนที่จะเร็วขึ้น

Linux & ESXi Variants:

- **Double XOR Ridicule:** มีข้อผิดพลาดในการเข้ารหัสแบบ XOR สองรอบ ซึ่งจะหักล้างกันเองทำให้สตริงที่ควรถูกซ่อนถูกเปิดเผยกลับเป็นข้อความธรรมดา
- **Broken ASCII Art:** ในเวอร์ชัน Linux และ ESXi มีการพยายามสร้าง ASCII Art แต่ผู้พัฒนาลืมหลักอักขระ ทำให้ภาพแสดงผลผิดเพี้ยน
- **Outdated Geofencing:** ลิขสิทธิ์รายชื่อประเทศห้ามโจมตียังรวม "ประเทศยูเครน" เอาไว้ ซึ่งกลุ่ม Ransomware ปัจจุบันมักนำยูเครนออกแล้ว พฤติกรรมนี้ชี้ว่าอาจใช้โค้ดเก่าหรือใช้ AI สร้าง



Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1195.002	Supply Chain Compromise: Compromise Software Dependencies and Development Tools
Execution	T1059	Command and Scripting Interpreter
Persistence	T1053	Scheduled Task/Job
Defense Evasion	T1562.009	Safe Mode Boot
	T1562.001	Impair Defences: Disable Tools
Discovery	T1046	Network Service Discovery: DFS/SMB
	T1082	System Information Discovery
	T1083	File and Directory Discovery
Lateral Movement	T1021.002	Remote Services: SMB/Admin Shares
	T1021.006	Remote Services: WinRM
Impact	T1486	Data Encrypted for Impact
	T1490	Inhibit System Recovery
	T1489	Service Stop



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

sha256

a7eadcf81dd6fda0dd6affefaffcb33b1d8f64ddec6e5a1772d028ef2a7da0f2
58e17dd61d4d55fa77c7f2dd28dd51875b0ce900c1e43b368b349e65f27d6fdd
e1fc59c7ece6e9a7fb262fc8529e3c4905503a1ca44630f9724b2ccc518d0c06
8ee4ec425bc0d8db050d13bbff98f483fff020050d49f40c5055ca2b9f6b1c4d
9c745f95a09b37bc0486bf0f92aad4a3d5548a939c086b93d6235d34648e683f
e512d22d2bd989f35ebaccb63615434870dc0642b0f60e6d4bda0bb89adee27a

domain

bu7zr6fotni3qxxoxlcmpikwtp5mjzy7jkxt7akflnm2kwkdbdtgtjuid.onion

email-src

qilin@exploit.im

ip-dst

158.94.210.11

Filename

svc_host_update.exe

enc_esxi.elf

VECT_RECOVERY_GUIDE.txt

README_VECT.html



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- **ตรวจสอบการแก้ไขค่าการบูตระบบ:** เฝ้าระวังการรันคำสั่งที่ผิดปกติ เช่น `bcdedit /set {default} safeboot minimal` ซึ่งมัลแวร์ใช้เพื่อบังคับบูตระบบเข้าสู่ Safe Mode เพื่อหลบเลี่ยงการทำงานของซอฟต์แวร์ความปลอดภัย
- **เฝ้าระวังการดัดแปลง Firewall ของ Hypervisor:** ตรวจสอบการใช้คำสั่ง `esxcli` บน VMware ESXi โดยเฉพาะความพยายามในการปิด Firewall หรือแก้ไข Network Rulesets และการหยุดการทำงานของ VM
- **ตรวจจับการลบ Shadow Copies:** เฝ้าระวังการเรียกใช้งานคำสั่ง `vssadmin delete shadows /all /quiet` ซึ่งเป็นการขัดขวางกระบวนการกู้คืนระบบ
- **เฝ้าระวังการเคลื่อนที่แนวนอน (Lateral Movement):** ตรวจสอบเครือข่ายสำหรับพฤติกรรมที่ผิดปกติผ่านโปรโตคอล SSH (เช่น การพยายามเข้าถึงไฟล์ `known_hosts` หรือการใช้ SCP คัดลอกไฟล์) บน Linux/ESXi รวมถึงการใช้ WMI, SMB และ GPO บนแพลตฟอร์ม Windows

การป้องกัน (Prevention)

- **จัดทำระบบสำรองข้อมูลแบบออฟไลน์ (Offline Backups):** เป็นมาตรการที่สำคัญที่สุดเนื่องจาก VECT 2.0 มีข้อบกพร่องที่ลบค่า Nonce ทิ้ง ทำให้ไฟล์ที่มีขนาดใหญ่กว่า 128 KB ถูกทำลายอย่างถาวร องค์กรจึงต้องพึ่งพาข้อมูลสำรองที่ไม่ได้เชื่อมต่อกับเครือข่ายหลักเท่านั้น
- **Block IOCs:** นำค่าแฮช (SHA-256) ของ VECT 2.0 ไปตั้งค่าการบล็อกในระบบรักษาความปลอดภัย (Endpoint/Network Security)
- **ควบคุมและจำกัดสิทธิการเข้าถึงเครือข่ายระยะไกล:** เข้มงวดกับการยืนยันตัวตนและการเข้าถึงเซิร์ฟเวอร์จัดการ เช่น SSH และ SMB เพื่อลดโอกาสที่มัลแวร์จะกระจายตัวจากเครื่องหนึ่งไปยังเครื่องอื่น



การรับมือ (Response)

- **ห้ามจ่ายค่าไถ่เด็ดขาด:** การจ่ายค่าไถ่จะไม่ได้ผล เนื่องจากความผิดพลาดในการเขียนโปรแกรมของ VECT ทำให้ไฟล์เกือบทั้งหมด (ไฟล์ที่ใหญ่กว่า 128 KB) สูญเสียค่าที่จำเป็นในการถอดรหัสไปแล้ว 3 ใน 4 ส่วน ไม่ว่าใครก็ไม่สามารถกู้คืนข้อมูลให้กลับมาสมบูรณ์ได้
- **แยกอุปกรณ์ที่ติดเชื้อ:** หากตรวจพบการบุกรุก ให้รีบตัดการเชื่อมต่อเครื่องที่มีการบุกรุกนั้นออกจากเครือข่ายเพื่อป้องกันการแพร่กระจาย
- **เก็บหลักฐานทางดิจิทัล:** รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics)
- **กู้คืนระบบ:** กู้คืนระบบจาก Backup แบบออฟไลน์ที่ปลอดภัย หลังจากได้รับการยืนยันว่าได้ทำการอัปเดตความปลอดภัยและล้างมัลแวร์ออกจากเครือข่ายเรียบร้อยแล้ว
- **รายงานเหตุการณ์:** แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์



อ้างอิง (References)

1. Check Point Research. (2026, April 28). VECT: Ransomware by design, wiper by accident. <https://research.checkpoint.com/2026/vect-ransomware-by-design-wiper-by-accident/>
2. Moran, S. (2026, April 28). *Bugs & betrayal – Vect analysis*. JUMPSEC. <https://www.jumpsec.com/guides/vect-ransomware-analysis/>
3. Data Security Council of India. (2026, February). DSCI threat intelligence and research initiative: Threat report February 2026. <https://www.dsci.in/files/content/advisory/2026/threat-report-feb-2026.pdf>
4. Darkatlas Squad. (2026, April 27). *In-depth technical analysis of VECT ransomware*. Buguard. <https://darkatlas.io/blog/in-depth-technical-analysis-of-vect-ransomware>
5. Shenouda, J. (2026, January 16). New threat actor: Vect ransomware group. Joe Shenouda | Threat Intelligence. <https://www.shenouda.nl/new-threat-actor-vect-ransomware-group/>
6. Kaspersky Team. (2026, March 25). *Supply chain attack via Trivy and LiteLLM*. Kaspersky Official Blog. <https://www.kaspersky.com/blog/critical-supply-chain-attack-trivy-litellm-checkmarx-teampcp/55510/>
7. National Vulnerability Database. (2026, March 23). *CVE-2026-33634 detail*. National Institute of Standards and Technology. <https://nvd.nist.gov/vuln/detail/CVE-2026-33634>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th